

## (a) Marco integrativo GQM + PRAGMATIC para indicadores SOC 2 – ENS – NIS2

### 1. Introducción

Este documento define un marco integrativo que combina la metodología GQM (Goal–Question–Metric) con los criterios PRAGMATIC para evaluar la calidad de las métricas de seguridad asociadas a los indicadores propuestos en el informe SOC 2 – ENS – NIS2.

GQM garantiza que cada métrica esté trazada a objetivos claros (estratégicos, tácticos u operativos), mientras que PRAGMATIC evalúa si la métrica es útil, fiable y explotable para la toma de decisiones.

### 2. Resumen de GQM

- **Goal (Objetivo):** Qué se quiere lograr o comprender (p. ej. “Mejorar la gobernanza de la ciberseguridad”).
- **Question (Pregunta):** Qué preguntas permiten determinar si el objetivo se está cumpliendo (p. ej. “¿La alta dirección recibe información periódica y cuantitativa sobre ciberseguridad?”).
- **Metric (Métrica):** Qué datos cuantitativos o cualitativos responden a esas preguntas (p. ej. “frecuencia de reporting”, “número de indicadores revisados”).

### 3. Resumen de PRAGMATIC

Cada métrica se evalúa según nueve criterios, asignando, por ejemplo, una valoración de 0 a 3 (0 = no cumple, 3 = cumple muy bien):

- **P – Predictivo:** ¿Ayuda a anticipar resultados futuros o tendencias?
- **R – Relevante:** ¿Está alineada con los objetivos de negocio y regulatorios?
- **A – Accionable:** ¿Sugiere acciones claras cuando la métrica cambia?
- **G – Genuino:** ¿Refleja la realidad sin incentivar comportamientos engañosos?
- **M – Significativo (Meaningful):** ¿Es comprensible y significativa para los decisores?
- **P – Preciso:** ¿Es suficientemente exacta y consistente?
- **T – Oportuno (Timely):** ¿Puede obtenerse con la frecuencia necesaria?
- **I – Independiente:** ¿Depende mínimamente de opiniones subjetivas individuales?
- **C – Rentable (Cost-effective):** ¿El esfuerzo de medirla compensa el valor que aporta?

## 4. GQM + PRAGMATIC por ejes principales (ejemplos clave)

### 4.1 Gobernanza (CC1) – Ejemplo de objetivo y métrica

**Objetivo G1:** Asegurar que la alta dirección ejerce una gobernanza efectiva de la ciberseguridad alineada con SOC 2, ENS y NIS2.

**Pregunta Q1.1:** ¿La alta dirección aprueba y revisa periódicamente una estrategia de ciberseguridad con objetivos y métricas?

**Métrica M1.1:** Frecuencia de revisión formal de la estrategia de ciberseguridad por parte de la alta dirección (nº de revisiones/año).

Evaluación PRAGMATIC propuesta:

- Predictivo: 2 – Permite anticipar si la gobernanza será reactiva o proactiva.
- Relevante: 3 – Directamente vinculada a requisitos de gobernanza ENS/NIS2.
- Accionable: 3 – Frecuencia baja sugiere acciones claras (revisión más frecuente).
- Genuino: 2 – Difícil de manipular, aunque puede maquillarse en actas.
- Significativo: 3 – Fácil de entender por dirección y auditores.
- Preciso: 3 – Conteo objetivo de reuniones/revisiones.
- Oportuno: 3 – Datos disponibles al menos anualmente.
- Independiente: 2 – Depende de registros de secretaría, no de opinión.
- Rentable: 3 – Bajo coste de obtención.

Puntuación total sugerida: 23/27.

#### 4.2 Riesgos (CC3) – Ejemplo de objetivo y métrica

**Objetivo G2:** Garantizar que los activos y servicios críticos están cubiertos por análisis de riesgos actualizados.

**Pregunta Q2.1:** ¿Qué porcentaje de activos y servicios críticos cuentan con análisis de riesgo actualizado en los últimos 12 meses?

**Métrica M2.1:** Porcentaje de activos/servicios críticos con análisis de riesgo actualizado  $\leq$  12 meses.

Evaluación PRAGMATIC propuesta:

- Predictivo: 3 – Alta correlación con exposición futura a incidentes.
- Relevante: 3 – Directamente alineada con SOC 2, ENS y NIS2.
- Accionable: 3 – Permite priorizar recursos hacia activos sin análisis.
- Genuino: 2 – Puede sobreestimarse si la clasificación de activos es incompleta.
- Significativo: 3 – Comprensible para todas las áreas.
- Preciso: 2 – Depende de la calidad del inventario de activos.
- Oportuno: 2 – Actualizable anualmente o semestralmente.
- Independiente: 2 – Basado en inventarios, pero con cierto juicio.
- Rentable: 2 – Requiere esfuerzo de inventario, pero manejable.

Puntuación total sugerida: 22/27.

#### 4.3 Monitorización (CC4) – Ejemplo

**Objetivo G3:** Reducir el tiempo medio de detección y respuesta a incidentes críticos.

**Pregunta Q3.1:** ¿Cuál es el tiempo medio de detección (MTTD) de incidentes críticos?

**Métrica M3.1:** MTTD para incidentes de severidad alta (en horas).

Evaluación PRAGMATIC propuesta:

- Predictivo: 3 – Fuerte capacidad predictiva sobre impacto final de incidentes.
- Relevante: 3 – Central para NIS2 y resiliencia.
- Accionable: 3 – Reducciones o aumentos sugieren acciones inmediatas.
- Genuino: 2 – Puede depender de cómo se define “detección”.
- Significativo: 3 – Métrica estándar en seguridad.
- Preciso: 2 – Requiere registros fiables de tiempos.
- Oportuno: 3 – Actualizable mensualmente.
- Independiente: 2 – Procesado a partir de datos técnicos.
- Rentable: 2 – Requiere SIEM/SOC bien configurado.

Puntuación total sugerida: 22/27.

#### 4.4 Controles técnicos (CC5-CC8) – Ejemplo

**Objetivo G4:** Aumentar el grado de automatización de controles de seguridad clave.

**Pregunta Q4.1:** ¿Qué porcentaje de controles de seguridad clave están automatizados?

**Métrica M4.1:** Porcentaje de controles de seguridad críticos implementados mediante mecanismos automatizados.

Evaluación PRAGMATIC propuesta:

- Predictivo: 2 – Sugiere menor dependencia de errores humanos.
- Relevante: 3 – Clave para eficiencia y cumplimiento continuo.
- Accionable: 3 – Facilita planes de automatización progresiva.
- Genuino: 2 – Puede haber debate sobre qué se considera “automatizado”.
- Significativo: 3 – Muy intuitivo para dirección y equipos técnicos.
- Preciso: 2 – Depende de inventario de controles.
- Oportuno: 2 – Actualizable anualmente.
- Independiente: 2 – Basada en registros de sistemas y juicio experto.
- Rentable: 2 – Requiere esfuerzo inicial de catalogación.

Puntuación total sugerida: 21/27.

#### 4.5 Accesos (CC6) – Ejemplo

**Objetivo G5:** Garantizar que el acceso a sistemas críticos se protege mediante MFA.

**Pregunta Q5.1:** ¿Qué porcentaje de cuentas de usuario de personal interno dispone de MFA en sistemas críticos?

**Métrica M5.1:** Porcentaje de cuentas internas con MFA habilitado para acceso a sistemas críticos.

Evaluación PRAGMATIC propuesta:

- Predictivo: 3 – Fuerte relación con probabilidad de compromiso de cuentas.
- Relevante: 3 – Directamente relacionado con requisitos modernos de seguridad.

- Accionable: 3 – Permite fijar objetivos de despliegue de MFA.
- Genuino: 2 – Puede verse afectada por definiciones de “crítico” y tipos de cuentas.
- Significativo: 3 – Fácil de explicar.
- Preciso: 3 – Datos obtenibles de directorios y sistemas de identidad.
- Oportuno: 3 – Actualizable trimestralmente o mensualmente.
- Independiente: 3 – Datos objetivos de sistemas.
- Rentable: 3 – Coste bajo con herramientas de gestión de identidades.

Puntuación total sugerida: 26/27.

#### 4.6 Disponibilidad y continuidad – Ejemplo

**Objetivo G6:** Asegurar la continuidad de servicios críticos conforme a SLA y ENS.

**Pregunta Q6.1:** ¿Cuál es el tiempo de indisponibilidad no planificada de servicios críticos respecto al SLA?

**Métrica M6.1:** Horas de caída no planificada de servicios críticos por periodo frente al objetivo definido.

Evaluación PRAGMATIC propuesta:

- Predictivo: 3 – Mejores valores anticipan resiliencia.
- Relevante: 3 – Central para ENS y servicios esenciales.
- Accionable: 3 – Aumentos disparan análisis de causa raíz.
- Genuino: 2 – Requiere criterios claros de “crítico” y “no planificado”.
- Significativo: 3 – Entendible del consejo al técnico.
- Preciso: 2 – Depende de calidad de monitorización.
- Oportuno: 3 – Actualizable mensual/trimestralmente.
- Independiente: 2 – Requiere clasificación y registros.
- Rentable: 2 – Monitorización ya necesaria para operación.

Puntuación total sugerida: 23/27.

#### 4.7 Confidencialidad – Ejemplo

**Objetivo G7:** Proteger los datos confidenciales mediante cifrado en reposo y en tránsito.

**Pregunta Q7.1:** ¿Qué porcentaje de datos confidenciales está cifrado en reposo?

**Métrica M7.1:** Porcentaje estimado de datos clasificados como confidenciales que están cifrados en reposo.

Evaluación PRAGMATIC propuesta:

- Predictivo: 2 – Reduce impacto de fugas, aunque no su probabilidad.
- Relevante: 3 – Directo para ENS y RGPD.
- Accionable: 3 – Indica dónde reforzar cifrado.
- Genuino: 2 – Depende de la calidad de la clasificación de datos.
- Significativo: 3 – Métrica estándar.

- Preciso: 2 – Estimaciones necesarias en entornos complejos.
- Oportuno: 2 – Actualización anual razonable.
- Independiente: 2 – Requiere inventario y juicio.
- Rentable: 2 – Coste moderado de levantamiento inicial.

Puntuación total sugerida: 20/27.

#### 4.8 Privacidad – Ejemplo

**Objetivo G8:** Cumplir plazos legales en el ejercicio de derechos de los interesados.

**Pregunta Q8.1:** ¿Qué tiempo medio de respuesta se da a las solicitudes de derechos?

**Métrica M8.1:** Tiempo medio de respuesta (días) a solicitudes de acceso/rectificación/supresión.

Evaluación PRAGMATIC propuesta:

- Predictivo: 2 – Indica riesgo de sanciones o quejas futuras.
- Relevante: 3 – Directamente vinculado a RGPD.
- Accionable: 3 – Tiempos altos exigen reforzar procedimientos.
- Genuino: 2 – Depende de registro fiel de solicitudes.
- Significativo: 3 – Métrica jurídica y operativa a la vez.
- Preciso: 3 – Fechas de registro y cierre bien definidas.
- Oportuno: 2 – Revisiones trimestrales/anuales.
- Independiente: 2 – Basada en registros, pero puede variar el criterio de cierre.
- Rentable: 3 – Datos fácilmente explotables del sistema de gestión.

Puntuación total sugerida: 22/27.

#### 4.9 Proveedores y cadena de suministro – Ejemplo

**Objetivo G9:** Gestionar adecuadamente los riesgos de ciberseguridad en la cadena de suministro.

**Pregunta Q9.1:** ¿Qué porcentaje de proveedores críticos ha sido evaluado formalmente en ciberseguridad en los últimos 24 meses?

**Métrica M9.1:** Porcentaje de proveedores críticos con evaluación de ciberseguridad reciente ( $\leq 24$  meses).

Evaluación PRAGMATIC propuesta:

- Predictivo: 2 – Sugiere probabilidad de exposición vía terceros.
- Relevante: 3 – NIS2 enfatiza la cadena de suministro.
- Accionable: 3 – Permite priorizar evaluaciones pendientes.
- Genuino: 2 – Depende de la definición de “crítico”.
- Significativo: 3 – Intuitivo para dirección y compras.
- Preciso: 2 – Requiere inventario y registros.
- Oportuno: 2 – Actualizable anualmente.

- Independiente: 2 – Basado en registros internos.
- Rentable: 2 – Coste asociado al programa de terceros.

Puntuación total sugerida: 21/27.